

Man-in-the-Middle (MITM) & DDoS Attacks

SOC Analyst Technical Reference Notes

Section 1: Man-in-the-Middle (MITM) Attacks

What is MITM?

- **Definition:** A Man-in-the-Middle (MITM) attack happens when an attacker secretly intercepts communication between two parties.
- **Communication Flow:**
 - Normal: User ↔ Server
 - Under Attack: User ↔ Attacker ↔ Server

Goals of a MITM Attack

- Steal credentials
- Capture session cookies
- Modify data in transit
- Inject malware
- Monitor sensitive communication

Types of MITM Attacks

1. ARP Spoofing (Very Important for SOC)

- **Mechanism:** The attacker tricks devices into thinking "I am the router," forcing network traffic to go through the attacker's machine.
- **Flow:** Victim → Attacker → Router → Internet
- **SOC Indicators:** Duplicate MAC addresses, ARP table changes, sudden traffic rerouting, and internal network anomalies.

2. DNS Spoofing

- **Mechanism:** The attacker redirects a domain name to a fake IP address (e.g., redirecting google.com to the attacker's server). This technique is very similar to phishing.

3. SSL Stripping

- **Mechanism:** The attacker downgrades the connection protocol from HTTPS to HTTP. The user believes the connection is secure when it is actually unencrypted.

4. Session Hijacking

- **Mechanism:** The attacker steals active session cookies to log into a service without needing the user's password.
- **Example:** User logs into a website → Attacker steals the cookie → Attacker gains unauthorized access.

5. Evil Twin

- **Mechanism:** The attacker sets up a fake WiFi network. Once a user connects to it, the attacker intercepts all their network traffic.

Real SOC Scenario: MITM Detection & Prevention

- **Alerts to Watch For:** Multiple users accessing the same gateway IP, SSL certificate mismatches, or suspicious DNS responses.
- **Investigation Steps:** Check the local ARP table, analyze DNS logs, and inspect network traffic for anomalies.
- **Prevention Measures:**
 - Enforce HTTPS (TLS encryption)
 - Implement VPN usage
 - Deploy Secure DNS (DNSSEC)
 - Ensure strict certificate validation
 - Implement network segmentation
 - Use WPA3 WiFi security standards

Section 2: Distributed Denial of Service (DDoS) Attacks

What is DDoS?

- **Definition:** A DDoS attack floods a target system with massive traffic to render it slow, unresponsive, or completely down.

Goals of a DDoS Attack

- Take a website offline
- Disrupt business operations
- Financial extortion ("Pay or we keep attacking")
- Use as a diversion to hide other ongoing malicious attacks

Types of DDoS Attacks

1. **Volumetric Attacks:** Designed to flood network bandwidth. Examples include UDP Floods and ICMP Floods.
2. **Protocol Attacks:** Designed to exhaust core server resources. Examples include SYN Floods and the Ping of Death.
3. **Application Layer Attacks:** Target specific applications or website functionalities (e.g., HTTP Floods, login endpoint abuse). These attacks are significantly harder to detect.

Real SOC Scenario: DDoS Detection & Mitigation

- **SOC Example Alert:** Traffic suddenly spikes from a normal baseline of 2k requests/sec up to an overwhelming 200k requests/sec coming from multiple countries and targeting the /login endpoint (Likely an Application Layer DDoS).
- **Real SOC Indicators:**
 - Sudden, massive spikes in traffic

- Identical requests originating from multiple distinct IPs
- Exceptionally high CPU/memory usage on infrastructure
- Increased latency and service downtime
- **DDoS Mitigation Techniques:**
 - Rate limiting
 - Web Application Firewall (WAF) deployment
 - Using CDNs (e.g., Cloudflare, Akamai)
 - Traffic filtering and load balancing
 - Aggressive IP blocking

Section 3: Interview Insights & Analyst Mindset

MITM vs. DDoS (Comparison Table)

Feature	MITM	DDoS
Goal	Intercept data	Disrupt service
Impact	Data theft	Service outage
Visibility	Stealthy	Noisy
Detection	Harder to detect	Easier to detect
Type	Confidentiality attack	Availability attack

SOC Analyst Thinking Matrix

- **Think MITM if you observe:** A suspicious certificate warning, users complaining about login hijacking, or a clear DNS mismatch.
- **Think DDoS if you observe:** A website going completely down, an unexplainable traffic spike, or severe server resource overload.